Operation Hydra - Multi-Vector Cyber Crime Investigation

Assignment 2, Unit 2: Types of Cyber Crimes. Simulated campaign: phishing, spoofing, malware injection, financial fraud. All entities fictional. Case OH-2026-0314.

Header analysis: 5/5 samples classified PHISHING/SPOOFED. Card-not-present (CNP) : 38 txns INR 342,900 UPI collect-request : 13 txns INR 278,580

docs/impactethicsreport.md

Operation Hydra -- Legal - Technical Impact Report

Simulated investigation report -- all persons, companies, accounts and artefacts are fictional and generated for academic assessment. Prepared by Nishant, Cyber Forensics Cell (simulation). Case ID OH-2026-0314, September 2026. Word count ? 3,100 * printed length 6 - 7 pages.

Abstract

Operation Hydra reconstructs a four-stage cyber-crime campaign against the fictional logistics firm Aurora Logistics Pvt. Ltd.: a spoofed-HR phishing wave, look-alike web infrastructure, a macro-dropped RAT with keylogger and logic-bomb components, and a Rs.6.21 lakh financial fraud layered through four mule accounts to a Bitcoin wallet. This report decomposes six offences, maps them to the IT Act 2000 (as amended), the Bharatiya Nyaya Sanhita 2023, and international instruments (CFAA, GDPR, Budapest Convention), and closes with stakeholder-impact assessment, ethical analysis and policy recommendations. Supporting evidence, scripts and logs are in the accompanying repository.

1. Introduction & methodology

Scope. Unit-2 assessment of types of cyber crimes through a simulated investigation.

Method. (i) synthetic evidence generation (e-mails, transactions, malware telemetry); (ii) standard open-tool analysis replicated offline -- header parsing with SPF/DKIM/DMARC verdicts, WHOIS domain-age analysis, abuse-IP scoring, payload decoding, ledger tracing; (iii) legal mapping per offence; (iv) ethical review.

Tooling. Eight Python scripts (standard library only) -- see README table. Real-world equivalents (MXToolbox, VirusTotal, AbuseIPDB) are documented with verbatim usage commands in evidence/tooloutputs/ so a reader can reproduce each step against live services.

Limitations. Everything is simulated; no live infrastructure was contacted. Legal citations are academic, not advice. The mixer-exit of the Bitcoin leg is deliberately unresolved and is used as an ethics exhibit.

2. Breakdown of cybercrime types

Six distinct offences (detailed tables in docs/cybercrimemapping.md):

1. Phishing / identity theft -- 212 spoofed mails, 41 harvested credentials -- IT Act S.66C, S.66D; BNS S.318(4), S.319(2); CFAA §1030(a)(4); Budapest Art. 7 - 8.
2. E-mail & web spoofing -- forged headers; clone portal on a 6-day-old domain -- IT Act S.66D, S.43; BNS S.338; CAN-SPAM analogue.
3. Unauthorized access -- 17 webmail/HR accounts accessed by the actor -- IT Act S.43/66; CFAA §1030(a)(2); Budapest Art. 2.
4. Malware injection -- HydraRAT (RAT + keylogger + logic bomb) -- IT Act S.43(c), S.66, S.66E; CFAA §1030(a)(5); Budapest Art. 3 - 4.
5. Card/UPI fraud & cheating -- 51 transactions, Rs.6,21,480 -- IT Act S.66C/D; BNS S.318(4); 18 U.S.C. §1029; PSD2 Art. 97.
6. Money laundering -- four mules -> P2P -> 0.71 BTC -- PMLA S.3/S.4; BNS S.111; Budapest Art. 11.

Aggregation note. One campaign, many offences: the phishing and spoofing charges are substantively distinct because spoofing criminalises the impersonation infrastructure whereas phishing criminalises the deception of the individual; charging both prevents double-jeopardy gaps identified in Sharat Babu v. State of A.P. style judgments.

3. Technical findings (summary)

- Authentication failure was the enabler. SPF hard-fail was visible at the gateway, but DMARC p=none meant no enforcement -- the single highest-value fix (-> §7 R1).
- Infrastructure told the story. Both clone domains were registered 6 - 9 days pre-attack behind privacy proxies; the clone-hosting IP range 103.87.12.0/24 also appears as the device-IP of two mule accounts -- tying phishing infrastructure to the laundering leg.
- The malware is a four-in-one. Trojan dropper (social-engineering delivery), RAT (interactive C2 verbs), keylogger (credential capture), logic bomb (72-hour wipe trigger). IoCs published in evidence/malware/iocs.json.
- The money is traceable until the mixer. 33% frozen within 24 h because mule patterns (velocity, dormancy, shared device IP) are machine-detectable; the 67% that exited via ATMs and P2P underlines that interdiction speed, not tracing skill, is the binding constraint.

4. Impact on stakeholders

Financial. Aurora Logistics: Rs.6,21,480 direct loss, ~470 employee-hours, 17 re-images, forensics retainer Rs.1.5 lakh (simulated) -> true cost ? 1.6x the fraud itself.

Victim-employees: individual out-of-pocket losses up to Rs.49,999; two SIM-swap victims bore secondary telecom costs.

Emotional/psychological. Six employees reported stress and loss of trust in internal communications; two filed formal grievances against the IT department; one victim (SIM-swap, Rs.49,999) reported sleep disruption and anxiety -- consistent with cybercrime-victimology findings that violation of trust produces greater distress than the monetary loss.

Reputational. One enterprise client issued a suspension-of-onboarding letter pending SOC-2 evidence; three press queries; the brand domain was impersonated in public, causing partner confusion. Post-incident, the company published a DMARC p=reject migration note to regain e-mail trust.

Systemic. The campaign consumed bank-fraud capacity, CERT-In response time and two registrar abuse queues -- the externalised cost every multi-vector attack imposes on third parties.

5. Legal remedies available

Victim/State | Remedy | Forum
Company | Compensation for S.43/66 loss | Adjudicating Officer, S.46 IT Act (Rs. cr.-limited civil)
Company/employees | Criminal complaint S.66/66C/66D IT Act + BNS 318/319/338 | Police cyber cell -> Magistrate
State | PMLA attachment of mule accounts | Enforcement Directorate -> Special Court
Registrants | Domain takedown | Registrar abuse (NameSilo/Namecheap) + NIXI .in registry
Bank customers | Chargeback / RBI Ombudsman (limited liability circulars 2017/2024) | Banking Ombudsman
Cross-border | MLAT via Budapest Convention channels (C1-C6 all dual-criminal) | CBI-INTERPOL desk

Evidence posture. All digital artefacts are accompanied by a S.65B IEA / S.63 BSA 2023 certificate (template in the repository's authorship declaration) -- without it, the .eml headers, CSV ledgers and memory images are inadmissible.

6. Ethical dilemmas

6.1 Tracing crypto vs. financial privacy. Cluster-heuristics and peel-chain analysis can de-anonymise innocent counterparties (exchanges, tip jars) that merely shared address-space with the launderer. The report resolves this by publishing methodology but withholding addresses beyond the confirmed criminal cluster -- minimisation analogous to GDPR data-minimisation.

6.2 Deceptive honeypots. Standing up a clone of the attacker's credential-harvest portal (honeypot aurora-hrportal.net) would identify victims before fraud, but constitutes personation (ironically, S.66D-adjacent) and risks entrapment claims; a passive sinkhole of the C2 (defensive, IT Act S.43 exception under "authorisation of the system owner") was chosen instead. The line drawn: deceive systems, not people.

6.3 Mule-account holders as offenders or victims? Two of four mules were students paid Rs.5,000 to "rent" accounts -- criminally liable (BNS 316(2)) yet arguably recruited-vulnerable persons. The report recommends prosecutorial discretion tiers, mirroring UK FCDO mule guidance.

6.4 Attribution restraint. Public naming of THREAT-ACTOR-HYDRA before evidentiary closure risks defamation (BNS S.356) and tip-off. Attribution statements here stay at infrastructure level ("actor-controlled") rather than identity level.

7. Recommendations

Public awareness

- R1 (highest leverage): DMARC p=reject + MFA everywhere -- this single pair defeats stages 1 - 2 of the campaign entirely.
- R2: quarterly simulation drills using samples generated by this repo's scripts (generatephishing.py) -- safe, reproducible, no real lures.
- R3: school/college module on UPI collect-request fraud -- 13 of 51 frauds needed only the victim pressing "Approve".

Policy

- R4: mandate real-time mule screening (device-IP overlap + dormancy + velocity) with a 60-second interdiction SLA -- would have frozen 100% instead of 33%.
- R5: extend RBI limited-liability rules explicitly to keylogger-harvested credentials (currently card-centric).
- R6: require VASP travel-rule enforcement for P2P desks above Rs.50k (AMLD/FATF alignment).
- R7: national domain-takedown fast lane (<= 24 h) for look-alike brand domains, modelled on the NIXI/registry abuse process.

Technical controls -- EDR on finance endpoints, macro-blocking from internet-origin files, out-of-band verification for payroll/HR mails, JIT privileged access.

8. Conclusion

Operation Hydra demonstrates that a mid-sophistication actor can chain four crime classes into a single loss event -- and that each link leaves forensic residue detectable with free tooling and disciplined log discipline. The legal framework (IT Act + BNS + PMLA) covers every offence observed; the systemic gaps are enforcement speed and preventive hygiene, both addressed in §7. The repository's reproducible scripts and synthetic evidence provide a safe template for repeat exercises.

References

1. Information Technology Act 2000 (India), as amended by ITAA 2008 -- S.43, 65, 66, 66B - 66F, 78.
2. Bharatiya Nyaya Sanhita 2023 -- S.303, 305, 316, 318, 319, 326(g), 338, 111.
3. Prevention of Money Laundering Act 2002 -- S.3, 4, 5.
4. Evidence: S.65B Indian Evidence Act 1872 / S.63 Bharatiya Sakshya Adhiniyam 2023.
5. Computer Fraud and Abuse Act, 18 U.S.C. §1030; access-device fraud §1029; laundering §1956/§1957.
6. EU GDPR (2016/679) Art. 5, 32, 33; PSD2 (2015/2366) Art. 97; AMLD5/6.
7. Council of Europe, Budapest Convention (ETS 185, 2001) & 2AP (2022).
8. MITRE ATT&CK v15 -- T1566, T1204, T1547, T1056, T1041, T1486.
9. RBI Master Direction on Digital Payment Security Controls (2021); Limited Liability Circulars.
10. FIU-IND VASP registration circular (March 2023).

docs/cybercrimemapping.md

? Cybercrime Decomposition & Legal Mapping

Assignment sub-problem 1. Six distinct offences are deconstructed below and mapped to Indian law (IT Act 2000 as amended by ITAA 2008, and the Bharatiya Nyaya Sanhita 2023 which replaced the IPC) and to global equivalents (US CFAA, EU GDPR, Council of Europe Budapest Convention ETS 185).

Legal mapping is for academic discussion. This is not legal advice. Section numbers are cited as taught in Unit 2; practitioners must verify current texts.

Crime index (6 distinct offences)

| Crime | Where in the case
C1 | Phishing / identity theft | 212 spoofed e-mails, 41 credential harvests
C2 | E-mail & web spoofing | spoofed hr@auroralogistics.in, clone portal aurora-hrportal.net
C3 | Unauthorized access | 17 accounts logged into by actor with stolen creds
C4 | Malware injection (RAT/keylogger) | INVOICEMAR2026.pdf.xlsm -> HydraRAT implant
C5 | Card/UPI financial fraud + cheating | Rs.6.2 lakh drained via CNP + collect-request frauds
C6 | Money laundering via mules & crypto | 4 mule accounts -> P2P -> BTC bc1qhydra...

C1 -- Phishing & identity theft

Jurisdiction | Provision | Fit
IT Act | S.66C -- identity theft (dishonest use of another's unique ID: e-mail id, password) | harvesting credentials = identity theft
IT Act | S.66D -- cheating by personation using a computer resource | fake HR sender
BNS 2023 | S.318(4) -- cheating (old IPC §420) | inducement to surrender credentials
BNS 2023 | S.319(2) -- cheating by personation (old IPC §416/417) | impersonating HR
US | 18 U.S.C. §1028A (aggravated identity theft), CFAA §1030(a)(4) | access device / credential abuse
EU | GDPR Art. 32 (processor duty -- breached by both sides: employer's mail flow, harvested PI) | data protection angle
Budapest | Art. 7 (computer-related forgery), Art. 8 (computer-related fraud) | cross-border prosecution basis

Punishment (India): S.66C -- up to 3 yrs + Rs.1 lakh; S.66D -- up to 3 yrs + Rs.1 lakh; BNS 318(4) -- up to 7 yrs + fine.

C2 -- E-mail & web spoofing

Jurisdiction | Provision | Fit
IT Act | S.66D -- personation using computer resource (spoofed From:, clone site) | core provision
IT Act | S.43 -- unauthorised access to a computer resource (company mail server relaying) | civil liability + compensation
BNS 2023 | S.338 -- forgery of electronic records (old IPC §463/468, forged headers) | forged Reply-To/headers
US | CAN-SPAM §7704 (header falsification) + CFAA | header spoofing
EU | GDPR Art. 5(1)(a) fairness in processing harvested employee data | --
Budapest | Art. 7 | electronic forgery

Punishment (India): S.66D -- up to 3 yrs + Rs.1 lakh.

C3 -- Unauthorized access

Jurisdiction | Provision | Fit
IT Act | S.43 read with S.66 -- accessing webmail/HR portal accounts without authorisation | 17 accounts
IT Act | S.66(2) aggravated where identity is dishonestly used | --
BNS 2023 | S.305 -- theft/dishonest intention in respect of property incl. intangible | credential misuse
US | CFAA 18 U.S.C. §1030(a)(2)/(4) -- unauthorised access to obtain information | exact analogue
EU | NIS2 Directive Art. 21 (security measures) -- employer-side duty breach | supervisory angle
Budapest | Art. 2 -- illegal access | first substantive offence

Punishment (India): S.66 -- up to 3 yrs + Rs.5 lakh (civil: damages under S.43/45).

C4 -- Malware injection (RAT + keylogger + logic bomb)

Jurisdiction | Provision | Fit
IT Act | S.43(c) -- introduction of computer contaminant | implanting HydraRAT
IT Act | S.66 + S.66F (cyber-terrorism arguable if critical infra; kept at S.66 here) | system damage
IT Act | S.66E -- violation of privacy (keylogger capturing private communications) | keystrokes incl. passwords
IT Act | S.66B -- dishonestly receiving stolen computer resource | handling exfiltrated data
BNS 2023 | S.303(2) theft; S.326(g) mischief by computer (old IPC §426/§66 IT Act bridge) | persistence + logic bomb
US | CFAA §1030(a)(5) -- transmission of a program causing damage | precise match for the implant
EU | GDPR Art. 33 -- 72-hour breach notification duty triggered | employer compliance failure
Budapest | Art. 4 (data interference), Art. 3 (illegal interception for keylogger) | dual fit

Punishment (India): S.66E -- up to 3 yrs + Rs.2 lakh; S.66F -- up to life if terrorism limb met.

C5 -- Card / UPI financial fraud

Jurisdiction | Provision | Fit
IT Act | S.66C identity theft (card data, UPI PIN) | --
IT Act | S.66D cheating by personation (3-D Secure OTP impersonation calls) | --
BNS 2023 | S.318(4) cheating; S.316(2) criminal breach of trust (for the mule holders who assisted) | --
RBI | Payment System Operators rules -- UPI collect-request misuse notification (2023 guidelines) | regulatory breach by PSP
US | 18 U.S.C. §1029 (access-device fraud) | CNP card fraud

EU | PSD2 Art. 97 strong-customer-authentication bypass | bank-side liability
Budapest | Art. 8 computer-related fraud | --
Punishment (India): BNS 318(4) -- up to 7 yrs + fine; restitution under S.395 BNSS (victim compensation).

C6 -- Money laundering (mule accounts -> crypto)

Jurisdiction | Provision | Fit
PMLA 2002 | S.3 (proceeds of crime) & S.4 punishment; scheduled offence = BNS 318(4) | layering via 4 mules
IT Act | S.66B receiving stolen computer resource (crypto purchased with proceeds) | --
BNS 2023 | S.111 organised crime (small-value, repeated, syndicated) | --
US | 18 U.S.C. §1956/§1957 (money laundering), §1960 (unlicensed money transmitting -- P2P desk) | --
EU | AMLD5/AMLD6 -- VASP KYC duty evaded by P2P cash-out | --
Budapest | Art. 11 laundering of the proceeds of cyber-crime | added by 2AP
Punishment (India): PMLA S.4 -- rigorous imprisonment 3 - 7 yrs + fine up to Rs.5 lakh.

Responsibility matrix

Actor role | Offences
THREAT-ACTOR-HYDRA (principal) | C1, C2, C3, C4, C5, C6
Phishing-kit vendor (infra as a service) | C1, C2 (abetment S.65 IT Act / S.61 BNS)
Mule account holders (4) | C5 (CBT), C6 (PMLA layering)
P2P crypto desk | C6 (S.1960 US; PMLA S.3 if knowledge proved)
Compromised cPanel host owner (45.142.213.107) | negligent -- S.43 IT Act civil only

Appellate & forum notes (for the report)

- Adjudicating officer: MeitY-appointed AO under S.46 IT Act for S.43/66 civil compensation.
- Criminal trial: Magistrate, Pune; police complaint under S.66C/66D/66 IT Act (police may investigate offences with imprisonment > 3 yrs -- S.78 IT Act).
- PMLA: Enforcement Directorate complaint before Special PMLA Court.
- Evidence: S.65B(4) Indian Evidence Act (now S.63 BSA 2023) certificate mandatory for the .eml files, transaction CSV and memory dumps -- produced in docs/AUTHORSHIPDECLARATION.md.

docs/phishinginvestigation.md

Phishing & Spoofing Investigation

Assignment sub-problem 2. Analysis of the five synthetic samples in
evidence/phishing/. Tool equivalents: MXToolbox header analyzer,
VirusTotal URL scanner, AbuseIPDB, WHOIS. All header/SPF/DKIM/DMARC parsing in this doc was
produced by analysis/scripts/analyzeheaders.py; raw log in analysis/logs/02headers.log.

---

1. Sample inventory

Sample | From (displayed) | Return-Path | Subject | Attachments/URLs | Verdict

hydra01.eml | "Aurora HR" <hr@auroralogistics.in> | bounce@hydrapey.net | Urgent: Pilot Leave Roster | http://aurora-hrportal.net/login | phishing

hydra02.eml | "IT Helpdesk" <support@auroralogistics-support.com> | same | Password expires in 24h | /sso/reset | phishing

hydra03.eml | "Payroll Team" <payroll@auroralogistics.in> | same | Revised salary slip -- Mar 2026 | .html attachment (credential form) | phishing

hydra04.eml | "Travel Desk" <travel@auroralogistics.in> | same | Pilot duty change -- confirm | bit.ly/3hydraX (open redirect) | phishing

hydra05.eml | "Nodal Officer" <compliance@auroralogistics.in> | same | KYC re-verification before 31 Mar | auroralogistics-support.com/kyc | phishing

2. Header forensics (full Received chain -- hydra01)

```
Received: from mail.hydrapey.net (45.142.213.107)  <- true origin (NL, AS208475)
          by mx.auroralogistics.in with ESMTPS id 8f2a...
Received-SPF: fail (domain owner discourages this sender)  <- hard fail (-all)
Authentication-Results: mx.auroralogistics.in;
        spf=fail smtp.mailfrom=auroralogistics.in;
        dkim=none; dmarc=fail (p=none, disposition=none)  <- DMARC policy weak!
Reply-To: hr.verify@aurora-hrportal.net  <- REAL reply destination (different domain)
X-Mailer: PHPMailer 6.8.0 (classic kit fingerprint)
```

Tells

1. Return-Path domain != From domain (bounce laundering via hydrapey.net).
2. SPF hard fail: real auroralogistics.in publishes v=spf1 include:spf.google.com -all.
3. DKIM none -> no signature from the claimed domain.
4. DMARC p=none -> policy exists but takes no action; this is why the mail reached inboxes.
5. Reply-To points to the attacker-controlled clone domain -- a dead giveaway.
6. X-Mailer: PHPMailer + missing Message-ID from the real domain -> scripted mass-mailer.

3. SPF / DKIM / DMARC records (recreated via dig TXT)

```
auroralogistics.in.            TXT "v=spf1 include:spf.google.com -all"
dmarc.auroralogistics.in.     TXT "v=DMARC1; p=none; rua=mailto:dmarc@auroralogistics.in"
aurora-hrportal.net.           TXT "v=spf1 +all"          <- allows anything (kit host)
hydrapey.net.                  TXT "v=spf1 ip4:45.142.213.0/24 +all"
; selector checks: google.domainkey.auroralogistics.in EXISTS; s1.domainkey absent
```

Fix recommended in report: move DMARC to p=reject with rua aggregation before T+30 days.

4. WHOIS intelligence (analysis/logs/04whois.log)

Domain | Created | Registrar | Age at attack | Red flag

auroralogistics.in | 2011-06-02 | GoDaddy | 14.8 y | genuine

aurora-hrportal.net | 2026-03-08 | NameSilo (PrivacyGuard) | 6 days | brand-new + privacy

auroralogistics-support.com | 2026-03-05 | Namecheap (WhoisGuard) | 9 days | brand-new + privacy

hydrapey.net | 2026-01-11 | Njalla (privacy shell) | 2 mo | stager/bounce infra

5. IP intelligence (AbuseIPDB-style scoring -- analysis/logs/03iptrace.log)

IP | rDNS | ASN / Country | Abuse score | Notes

45.142.213.107 | mail.hydrapey.net | AS208475 / NL | 96/100 | phishing relay, 311 reports/90 d

185.220.101.47 | tor-exit-47.hydrapey.net | AS205100 / RO | 88/100 | C2 + Tor exit (dual use)

103.87.12.90 | ns1.aurora-hrportal.net | AS135318 / IN | 74/100 | clone-hosting (Pune VPS)

91.215.85.21 | cdn.auroralogistics-support.com | AS204601 / UA | 81/100 | kit CDN, TLS via Let's Encrypt

6. VirusTotal-style URL verdicts (evidence/tooloutputs/virustotalverdict.md)

URL | Engines flagging / total | Categories

aurora-hrportal.net/login | 18/93 | phishing, credential theft

auroralogistics-support.com/sso/reset | 15/93 | phishing

bit.ly/3hydraX -> aurora-hrportal.net/duty | 11/93 (redirect resolved) | phishing, open-redirect chain

7. Conclusion

The spoofing chain is fully mapped: hydrapey.net (bounce/relay, NL) -> spoofed From: of
auroralogistics.in -> clone portals on aurora-hrportal.net (IN) / auroralogistics-support.com (UA),
with every hop corroborated by header analysis, DNS authentication results, WHOIS age, and
abuse scoring. Remedy: DMARC p=reject, MFA, and takedown notices to the two registrars
(template in docs/impactethicsreport.md).

docs/malwareanalysis.md

Malware Payload Analysis

Assignment sub-problem 3. Specimen: INVOICEMAR2026.pdf.xlsm delivered 14 - 15 Mar 2026 to
17 workstations. The synthetic payload and telemetry live in
evidence/malware/; decoding/classification is done by
analysis/scripts/malwaredecoder.py (log: analysis/logs/05malware.log).
---

1. Delivery & dropper

Property | Value
File name | INVOICEMAR2026.pdf.xlsm
Size | 184,320 bytes
SHA-256 | 4f1f2a9c3b6d7e804f1f2a9c3b6d7e804f1f2a9c3b6d7e804f1f2a9c3b6d7e80
Trickery | double extension; xlsm icon changed to PDF; "Protected View -> Enable Content" social engineering
Macro | AutoOpen -> Dropper() (VBA, obfuscated with Chr() chains)

Dropper behaviour (from VBA Dropper())

1. Drops %APPDATA%\MsEdgeUpdate.exe (name imitates Microsoft Edge updater).
2. Payload is base64 -> XOR(0x5A) inside the macro; decoder in analysis/scripts/malwaredecoder.py.
3. Persistence: HKCU\Software\Microsoft\Windows\CurrentVersion\Run\MsEdgeUpdater.
4. Spawns MsEdgeUpdate.exe hidden (SWHIDE), deletes %TEMP%\inv7352.tmp anti-forensic marker.

2. HydraRAT -- classification

Evidence (decoded strings + samplelogs.txt) supports all three sub-categories:
Category | Evidence | Verdict
RAT | C2 socket 185.220.101.47:8443, command verbs SHELL/UPLOAD/DOWNLOAD/SLEEP | confirmed
Keylogger | thread klogstart, buffer %APPDATA%\cache95.db, SetWindowsHookEx reference | confirmed
Logic bomb | if(dayssinceinfection>3 and unpaidinvoice) then zapdocs() -- 72 h wipe trigger | confirmed (neutralised)
Worm / Botnet | no net use / no C&C botnet roster | excluded
Primary classification: Trojan-RAT with keylogging and time-triggered logic bomb.
(Family style comparable to Remcos/AsyncRAT tooling.)

3. Behaviour timeline (sandboxed detonation -- evidence/malware/samplelogs.txt)

```
T+0s    MsEdgeUpdate.exe spawned (hidden), hash written to run key
T+4s    TLS handshake to 185.220.101.47:8443 (JA3 mimics Edge 120)
T+9s    beacon: "hydra-rat v2.1 | host=AURORA-FIN02 | user=r.desai"
T+15s   keylogger thread started -> cache95.db
T+41s   enumeration: ipconfig, tasklist, dir \\fileshare\finance
T+78s   UPLOAD cache95.db (6.4 KB) to C2
T+120s  SLEEP 1800 command received -> dormant loop (beacon every 30 min)
```

4. Indicators of Compromise (IoCs)

Full machine-readable set: evidence/malware/iocs.json.
Type | Value
file-hash-sha256 (dropper) | 4f1f2a9c3b6d7e804f1f2a9c3b6d7e804f1f2a9c3b6d7e804f1f2a9c3b6d7e80
file-hash-sha256 (implant) | a1b2c3d4e5f60718293a4b5c6d7e8091a2b3c4d5e6f708192a3b4c5d6e7f8091
file-name | INVOICEMAR2026.pdf.xlsm
file-name | MsEdgeUpdate.exe
file-path | %APPDATA%\MsEdgeUpdate.exe, %APPDATA%\cache95.db
registry-key | HKCU\...\Run\MsEdgeUpdater
ipv4 (C2) | 185.220.101.47
ipv4 (relay) | 45.142.213.107
domain | hydrapey.net, aurora-hrportal.net, auroralogistics-support.com
url | hxxp://aurora-hrportal[.]net/login
JA3 | 8f4d3e5f6a7b8c9d0e1f2a3b4c5d6e7f (fake Edge TLS)

5. Mapping behaviour -> attack vector

ATT&CK-style stage | Technique | Vector link
Initial Access | T1566.002 spear-phishing link / attachment | HR-spoof e-mail wave
Execution | T1204.002 user-executed macro | "Enable Content"
Persistence | T1547.001 Run key | MsEdgeUpdater
Defence Evasion | T1036.005 masquerading as Edge updater; hidden window | naming + JA3
Credential Access | T1056.001 keylogging | cache95.db
Collection/Exfil | T1041 exfil over C2 TLS | UPLOAD verb
Impact | T1486 (logic-bomb wipe attempt) | 72 h trigger

6. Decoder output summary

```
Stage 1: base64  -> 214 bytes blob
Stage 2: XOR 0x5A -> "HYDRARAT:v2.1|C2=185.220.101.47:8443|KEY=7hYdR4|..." (18 config fields)
```

Config also reveals MITMPROXY=cdn.auroralogistics-support.com:3128 -- the malware tunnels
through the same spoofed-domain CDN used by the phishing kit, tying the malware stage to the
phishing infrastructure (single-actor correlation).

docs/financialfraud.md

Financial Fraud Tracing

Assignment sub-problem 4. Simulated payment-fraud scenario built from the compromised card and UPI credentials harvested by HydraRAT. Dataset: evidence/transactions/hydratransactions.csv (40 synthetic records); full analysis: analysis/logs/06funds.log, produced by analysis/scripts/tracefunds.py.

All accounts, cards, UPI VPAs and wallets below are synthetic and pass Luhn only as dummy data. They belong to no one.

---

1. Fraud typologies observed in the dataset

Type | Count | Amount | Mechanism

Card-not-present (CNP) | 38 (incl. 12 micro card-testing probes) | Rs.3,42,900 | dumped card data on a "dump shop"; 3-D Secure bypassed by OTP SIM-swap (2 employees)

UPI collect-request fraud | 13 | Rs.2,78,580 | victims approved fake "Aurora HR payroll refund" collect requests

Total | 51 | Rs.6,21,480 | matches the case-brief loss figure

2. Temporal pattern (the fingerprint)

```
10:00 - 12:00 IST  12 micro-probes (Rs.101 - Rs.500)                    <- card testing
02:41 - 02:47 IST  burst of 9 transactions (Rs.41k - Rs.49,999 each)   <- SOC alert trigger
02:47 - 03:15      11 more, throttled after the alert
daytime 15 Mar   12 low-value probes (Rs.101 - Rs.500, card testing)
16 Mar           8 cash-out drains to mules
```

Classic card-testing -> burst -> throttle -> drain lifecycle; the 02:47 burst is what a real rule engine (velocity > 5 txn/min & ticket 40 - 50k & new MCC 5999) would flag.

3. Money flow -- the layering chain

```
38 CNP + 13 UPI victims
        |  (Rs.6,21,480 across 51 txns)
        v
MULE-1  HDFC 4412  "Rakesh V."   Rs.2,04,000  <- pass-through within 11 min
MULE-2  ICICI 8830  "Sana K."    Rs.1,86,480  <- 7 withdrawals @ ATM (card cloned)
MULE-3  Paytm  2170  "Dummy Traders LLP" Rs.1,31,000 <- shell entity, GST fake
MULE-4  SBI   7791  "Imran S."    Rs.1,00,000  <- student account, opened 3 days prior
        |  consolidation to MULE-3 (Rs.5,21,480)
        v
P2P crypto desk (Telegram @hydraotc, simulated)  --  2 trades
        v
BTC wallet  bc1qhydra9f2x7k04mule7qq0wv8nzx3a9c0dpeel7   (0.71 BTC)
        +-- hop -> bc1q9x7wallet2hop0fake4addr5zz6789012345 (peel chain, 3 hops)
        +-- mixer exit (simulated)  --  endpoint not traced (documented gap)
```

Full hop-by-hop table: analysis/logs/06funds.log §"Ledger trace".

4. How the mules were identified

Signal | Evidence

Account age < 30 days | MULE-4 opened 3 days pre-campaign

Velocity in/out ? 100% within minutes | MULE-1 ledger

Dormant -> sudden Rs.1 - 2 lakh inflow | MULE-3

Shared device/IP fingerprints | MULE-2 & MULE-4 both from same mobile UA 103.87.12.0/24 (the clone-host range!)

Withdrawal pattern | 7 ATM pulls in 40 min across 2 cities -- impossible for genuine owner

5. Tracing the crypto leg (simulated)

```
bc1qhydra9f2... (receiving 0.71 BTC from 2 desk addresses)
   +- tx1 0.35 BTC -> bc1q9x7hop1fake... (T+3h)
        +- tx2 0.34 BTC -> bc1q9x7hop2fake... (T+9h, peel 0.01 fee)
             +- tx3 0.33 BTC -> mixer (SIMULATED  --  deliberately unresolvable)
```

Chain-analysis notes (methodology only): cluster by common-input-ownership heuristic, peel-chain detection, change-address labelling. Endpoint deliberately undocumented -> becomes an ethical-dilemma exhibit in the impact report (see §Ethics).

6. Legal hooks for the money trail

Step | Law

Card/UPI fraud | IT Act S.66C/66D + BNS S.318(4)

Mule holders | BNS S.316(2) criminal breach of trust; PMLA S.3 layering

P2P desk | PMLA S.3; US §1960 analogue

Freezing | PMLA S.5 attachment; S.102 CrPC (now BNSS S.106) seizure of mule accounts -- 2 frozen T+1

Crypto seizure | PMLA + IT Act S.66B; exchange KYC summons under FIU-IND VASP registration (2023)

7. Recovery outlook (report figure)

Rs.2,04,000 frozen in MULE-1/MULE-4 (33%); Rs.3,10,480 dissipated via ATMs/mixer (67%) -- the report uses this split to argue for real-time mule-account screening as the highest-leverage fix.